



**Cybersecurity
Council**



Mastering VAPT: Web, Mobile, Mobile, & Network Security

CyberZero 45 Days Cybersecurity Internship Program

Presented by Mohammad Khan



The banner features a portrait of Mohammad Khan, a man with a beard wearing a light green shirt, set against a dark blue background with a stylized mountain range and a large blue arc behind him. At the top left are the logos for CYBERZERO and CYBER SECURITY COUNCIL. At the bottom, there is a section for the CYBERZERO INTERNSHIP PROGRAM, including social media links and the website URL.

CYBERZERO | **CYBER SECURITY COUNCIL**

MOHAMMAD KHAN
(INFORMATION SECURITY MANAGER)

CYBERZERO INTERNSHIP PROGRAM
45 DAYS INTERNSHIP PROGRAM

Ready to dive into the world of Tech, Innovation & Real Projects?

[in CYBERZERO](#)
[CYBERZERO](#)
[CYBERZERO-G2X](#)
WWW.CYBERZERO.IN

Who am I ?

- Experience in the cybersecurity domain in BFSI sector.
- Has expertise in infrastructure penetration testing, including web & Mobile apps,
- Bachelor of Science in Information Technology (BSC-IT).
- Master of Science in Information Technology (MSC-IT Specialization in Cybersecurity).
- Post Graduate Diploma in Digital and Cyber Forensics and Related Law (P.G.D.-D.C.F.-R.L).
- CRTP, eCPPT Certified
- An open-minded person who writes articles and research papers.

Session Agenda: Your VAPT Journey

1 Introduction to VAPT

Setting the stage for vulnerability assessment and penetration testing.

2 The VAPT Lifecycle

Understanding the phases from reconnaissance to reporting.

3 Deep Dive: Web, Mobile, & Network VAPT

Exploring specific methodologies and common vulnerabilities.

4 Practical Application & Tools

Overview of essential tools used in real-world VAPT scenarios.

5 Hands-on Labs & Q&A

Opportunity for practical experience and addressing your questions.

Breaking Down VAPT: The What, Why, and How

Vulnerability Assessment (VA)

A systematic process of identifying and quantifying security weaknesses within a system, application, or network.

- Automated scans and manual checks.
- Provides a prioritized list of vulnerabilities.
- Focuses on discovery, not exploitation.

Penetration Testing (PT)

Simulates a real-world cyberattack to evaluate the security of a system by actively exploiting identified vulnerabilities.

- Goes beyond identification to prove exploitability.
- Identifies potential impact of a successful breach.
- Often performed by ethical hackers.

VA and PT are **complementary** processes, working together to provide a comprehensive security posture.

Why VAPT Matters: Securing Our Digital World



Mitigating Real-World Cyber Cyber Risks

Proactive identification of weaknesses before malicious actors exploit them, preventing data breaches and system compromises.



Ensuring Regulatory Compliance

Meeting industry standards like ISO 27001, PCI-DSS, and GDPR, avoiding hefty fines and legal repercussions.



Safeguarding Data & Reputation

Protecting sensitive information and maintaining trust with customers and stakeholders, which is invaluable in today's digital age.

VA vs. PT: Key Differences and Outcomes

Primary Goal	Identify vulnerabilities	Exploit vulnerabilities
Scope	Broad, covers many systems	Focused, targets specific systems
Methodology	Automated scanning, some manual checks	Manual exploitation, creative attack paths
Outcome	List of weaknesses, risk scores	Proof of concept, impact analysis
Required Skill	Technical knowledge, tools proficiency	Advanced ethical hacking, critical thinking

Both provide crucial insights, but PT demonstrates the **true risk** by showing how vulnerabilities can be leveraged by an attacker.

The VAPT Lifecycle: A Structured Approach



1. Reconnaissance

Gathering information about the target. This can be active (direct interaction) or passive (publicly available data).



2. Scanning & Enumeration

Identifying live hosts, open ports, services, and potential vulnerabilities on the target system.



3. Exploitation

Leveraging discovered vulnerabilities to gain unauthorized access or control over the target.



4. Post-Exploitation

Maintaining access, escalating privileges, and gathering more information from the compromised system.



5. Reporting

Documenting findings, outlining exploited vulnerabilities, impact, and providing actionable remediation recommendations.

Each phase builds upon the last, leading to a comprehensive security assessment.

Information Gathering (Reconnaissance)

Active Reconnaissance

- Direct interaction with the target system.
- More accurate, but potentially detectable.
- **Examples:** Port scanning, network mapping, vulnerability scanning.



Passive Reconnaissance

- Gathering information without direct interaction.
- Less detectable, relies on public data.
- **Examples:** OSINT (Open Source Intelligence), WHOIS lookups, social media analysis.



Web Application VAPT: Securing the Digital Frontend

Importance of Web Security

Web applications are often the primary interface between users and an organization's backend systems, making them frequent targets for attackers.

- Direct access to sensitive data (user credentials, financial info).
- Potential for supply chain attacks through vulnerable components.
- Impacts business operations and customer trust.

OWASP Top 10:

The Open Web Application Security Project (OWASP) Top 10 is a standard awareness document for developers and web application security.

- It represents a broad consensus about the most critical security risks to web applications.
- Understanding these risks is foundational for any web VAPT professional.



OWASP Top 10:

SN	OWASP Top 10	What it means	Example	Simple Analogy
1	Broken Access Control	Users can do things they shouldn't	A normal user can access admin pages or another user's account	Like someone with a guest pass getting into the VIP lounge
2	Cryptographic Failures	Sensitive data isn't protected properly (bad or no encryption).	Passwords stored in plain text, credit card data sent without HTTPS	Locking your house with a cheap toy lock
3	Injection	Attackers trick an application into running malicious code/queries	SQL Injection: typing ' OR 1=1 -- in a login form to bypass login	Like convincing a waiter to write a fake order in the kitchen
4	Insecure Design	The system is poorly designed from the start	No limit on failed login attempts ? brute force attack succeeds	Building a house without doors and adding locks later.
5	Security Misconfiguration	Settings are unsafe or left at defaults	Default passwords, unnecessary features left on, error messages showing too much info	Leaving your car unlocked with the keys inside
6	Vulnerable & Outdated Components	Using old, unpatched software or libraries with known flaws.	Running a website on an old version of WordPress with security bugs.	Using a cracked helmet from 10 years ago
7	Identification & Authentication Failures	Weak login and session management	No multi-factor authentication, session ids not expiring, weak passwords allowed	Handing out the same house key to everyone in your neighborhood
8	Software & Data Integrity Failures	Code or data can be tampered with because integrity checks are missing	Installing an update without verifying if it's from a trusted source	Accepting a sealed package without checking if the seal is broken
9	Security Logging & Monitoring Failures	Attacks happen but nobody notices	No alerts when multiple failed logins happen, or no logs of suspicious activities.	A store without security cameras or alarms
10	Server-Side Request Forgery (SSRF)	Attacker tricks the server into making requests it shouldn't	Using a web app to fetch http://localhost/admin that only the server should access.	Tricking your friend into handing over their house key by asking them to "pick something up" from their own safe

Common Web Application Vulnerabilities

SQL Injection (SQLi)

Injecting malicious SQL queries into input fields to manipulate or retrieve data from a database.

```
SELECT * FROM users WHERE username = 'admin'--'  
AND password = 'password'
```

Cross-Site Scripting (XSS)

Injecting malicious client-side scripts into web pages viewed by other users, allowing attackers to steal session cookies or deface websites.

```
<script>alert('XSS');</script>
```

Cross-Site Request Forgery (CSRF)

Tricking a logged-in victim into executing unwanted actions on a web application where they are authenticated.

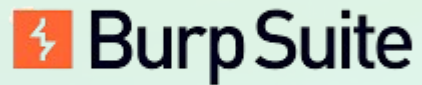
Often involves malicious links or hidden forms.

Insecure Direct Object References (IDOR)

Exposing internal implementation objects, such as file or database keys, in URLs or parameters, allowing attackers to manipulate them to access unauthorized data.

example.com/api/users?id=123

Essential Tools for Web VAPT



Burp Suite

A comprehensive platform for performing security testing of web applications, including an intercepting proxy, scanner, and intruder.



OWASP ZAP

An open-source web application security scanner that helps find vulnerabilities in web applications during development and testing.



Nikto

A web server scanner that performs comprehensive tests against web servers for multiple items, including over 6700 potentially dangerous files/CGIs.



Nmap

While primarily a network scanner, Nmap can also be used for web application reconnaissance by identifying open HTTP/HTTPS ports and detecting web server versions.

Mastering these tools is key to conducting effective web VAPT.



Comprehensive VAPT: Web, Mobile, Mobile, and Network

This session provides practical, hands-on guidance for security professionals and IT students on the core concepts and methodologies of Vulnerability Assessment and Penetration Testing (VAPT) across web, mobile, and network domains.

Mobile Application VAPT: Fundamentals

Android vs. iOS Security Models

Understanding the fundamental differences in security architectures between Android and iOS is crucial for effective mobile VAPT. Android's open-source nature allows for greater customization but can introduce fragmentation and varied security patch adoption. iOS, with its tightly controlled ecosystem and sandboxing, offers a more uniform security posture but can also present unique challenges for testers.



Mobile Security Issues & Attack Surface

Insecure Data Storage

Sensitive data, such as user credentials, API keys, or personal information, stored insecurely on the device (e.g., in plaintext files, shared preferences, or insecure databases) can be accessed by malicious applications or users.

Insecure Communication

Failure to use strong encryption (e.g., proper SSL/TLS implementation), certificate pinning, or relying on untrusted certificates can lead to Man-in-the-Middle (MitM) attacks, exposing data during transit.

Reverse Engineering Threats

Attackers can decompile mobile applications to understand their logic, extract sensitive information (like hardcoded API keys), or tamper with app functionality. Code obfuscation and anti-tampering measures are critical mitigations.

App Attack Surface

The mobile app attack surface extends beyond the app itself to include user input fields, exposed APIs, third-party libraries, inter-process communication (IPC) mechanisms, and interactions with the device's operating system.

Essential Tools for Mobile VAPT



An automated, all-in-one mobile application (Android/iOS/Windows) pen-testing, malware analysis, and security assessment framework capable of performing static and dynamic analysis.



A reverse engineering tool for Android apps that allows for decoding resources to nearly original form and rebuilding them after modifications, useful for examining application logic.



A dynamic instrumentation toolkit that allows for injecting custom scripts into processes to observe and modify runtime behavior, invaluable for bypassing security controls or debugging.



A comprehensive security assessment tool for Android that enables interaction with Android components (activities, services, content providers, broadcast receivers) at runtime.

Network VAPT: Uncovering Hidden Pathways

Internal vs. External Testing

Network VAPT typically involves two primary approaches: **External Testing**, which simulates attacks from outside the organization's perimeter (e.g., internet-based attackers), focusing on publicly exposed services. **Internal Testing** simulates an attack from within the network, often mimicking a compromised employee or insider threat.



Common Network Vulnerabilities

- **Open Ports & Unnecessary Services**

Leaving unnecessary ports open or running services that are not critical exposes potential entry points for attackers. Each open port represents a potential vulnerability if the associated service is not properly secured.

- **Outdated Software & Services**

Running older versions of operating systems, applications, or network services often means they contain known vulnerabilities that have been patched in newer versions but remain unaddressed, making them easy targets for exploitation.

- **Weak or Default Credentials**

Using easily guessable passwords, default vendor passwords, or hardcoded credentials makes systems highly susceptible to brute-force attacks or simple credential stuffing.

- **SMB Flaws**

Vulnerabilities in the Server Message Block (SMB) protocol, such as those exploited by EternalBlue, can allow attackers to gain remote code execution or spread malware across networks.

Key Tools for Network VAPT



Metasploit



Amass
OWASP*



OpenVAS
Open Vulnerability Assessment Scanner



These tools form the backbone of a network VAPT toolkit, offering capabilities ranging from network discovery and port scanning to vulnerability assessment and exploitation. Choosing the right tool depends on the specific testing phase and objective.

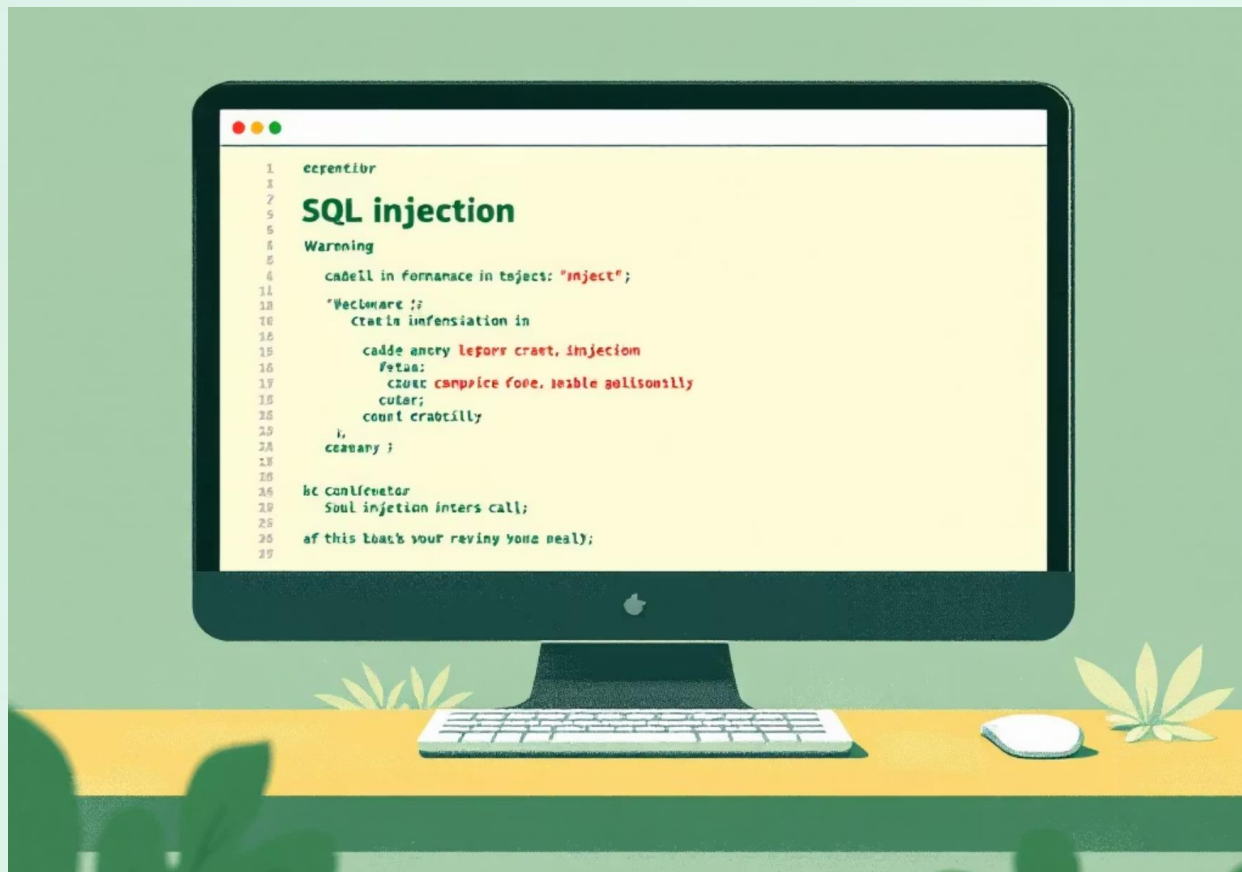
Practical Applications

Web VAPT Demo

- Utilizing intentionally vulnerable web applications like DVWA or Juice Shop.
- Live demonstration of SQL Injection to extract database information.
- Discussion and example of proper input sanitization and parameterized queries as mitigation.

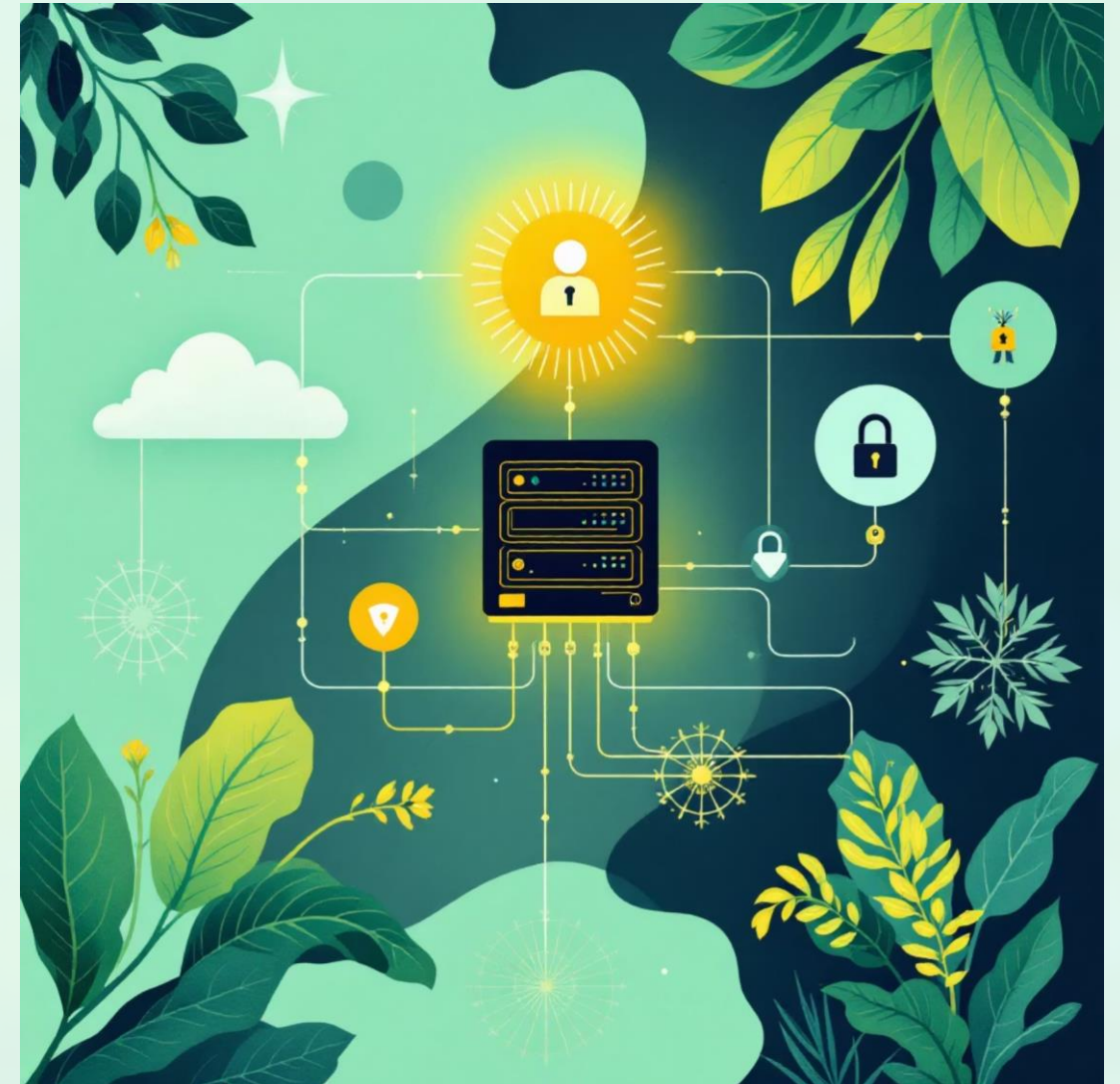
Mobile VAPT Demo

- Analyzing a vulnerable mobile application (e.g., InsecureBank or Damn Vulnerable Bank).
- Performing static analysis using MobSF to identify insecure data storage and communication patterns.
- Highlighting common findings from real-world mobile app assessments.



Network VAPT Demo

- Conducting a basic Nmap port scan against a target machine (e.g., Metasploitable1).
- Running a vulnerability scan with Nessus to identify known vulnerabilities.
- Demonstrating a simple exploit using Metasploit against a discovered vulnerability on Metasploitable2.



Best Practices for Reporting

Wrap-Up & Q&A

01

Key Takeaways

VAPT is a continuous process that requires a holistic approach across web, mobile, and network domains. Understanding the attack surface and employing the right tools and methodologies are critical for identifying and mitigating risks effectively.

02

Resources for Further Learning

OWASP Top 10 (Web & Mobile), SANS Institute resources, Exploit-DB, PortSwigger Web Security Academy, and various online courses for specific tools (e.g., Metasploit Unleashed).

03

Questions & Discussion

We encourage you to ask any questions you may have and share your own experiences or insights related to VAPT.



**Cybersecurity
Council**



Thank You

Questions...



mohammadkhan.infosec@gmail.com



+91 9004576253



mohammadkhanthk